



# 유기견 성향 분석 기반 추천 플랫폼 구축 및 정보보호 체계 강화 사업

**Security Report.**

서서울 | 윤철민 | 오명근 | 서정원 | 이주환

# Table Of Contents

## 01 프로젝트 배경

- 추진배경
- 고객사 설명
- 시나리오
- 사업 목표
- 사용 툴
- 프로젝트 기간
- 수행 인력

## 02 분석 및 점검

- 점검 기준
- 점검 항목
- 자산 목록
- 점검 범위
- 기존 고객사 인프라
- 개선된 인프라
- 보안 장비

## 03 개인 발표

- 담당 업무
- 취약점
- 시나리오
- 보안 점검
- 트러블 슈팅
- 프로젝트 후 느낀 점

## 04 Q & A

- 질의 응답



# 01 프로젝트 배경



## 추진 배경

사이버 보안 위협의 지속적 증가 및 대응 필요

보안 관련 법적 규제 준수 및 안정적 인프라 요구

통합 보안 체계 구축을 통한 안전한 운영 환경 마련

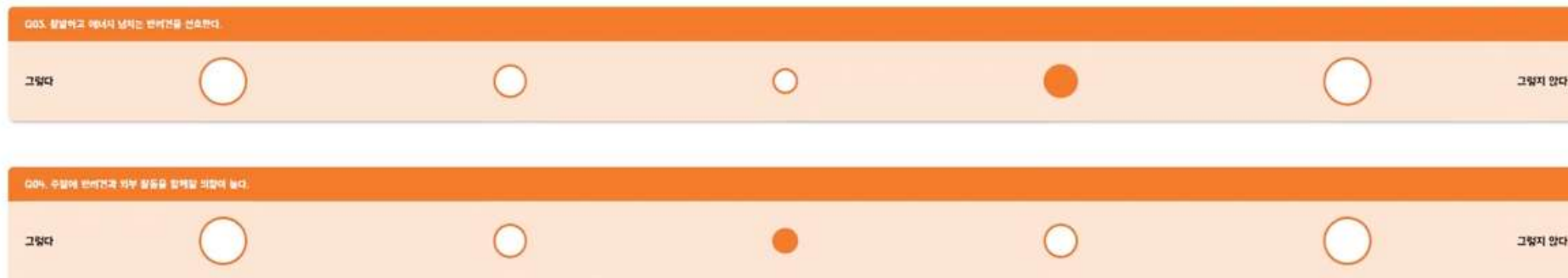
DingDongDog! 플랫폼의 핵심 데이터 보호 및 신뢰성 확보



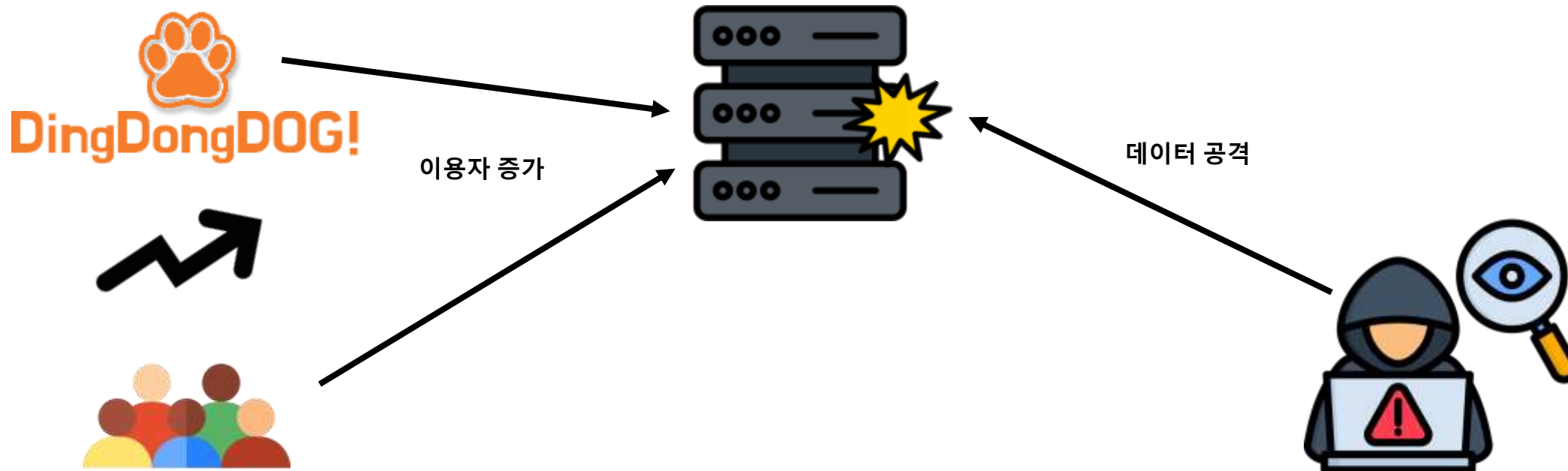
## 고객사 설명

"멍 ! 매칭으로 찾는  
나만의 반려견, 덩동독!"

DingDongDOG!



DingDongDOG!은 단순한 유기견 정보 공유를 넘어,  
유기견의 데이터 기반의 멍! 매칭을 통해 반려견과 입양 가족을 가장 행복하게 연결하는 입양 플랫폼입니다.



이용자 증가로 인해 회원 및 보호소 정보 등 주요 데이터를 노리는 공격 위험 증대



## 시나리오

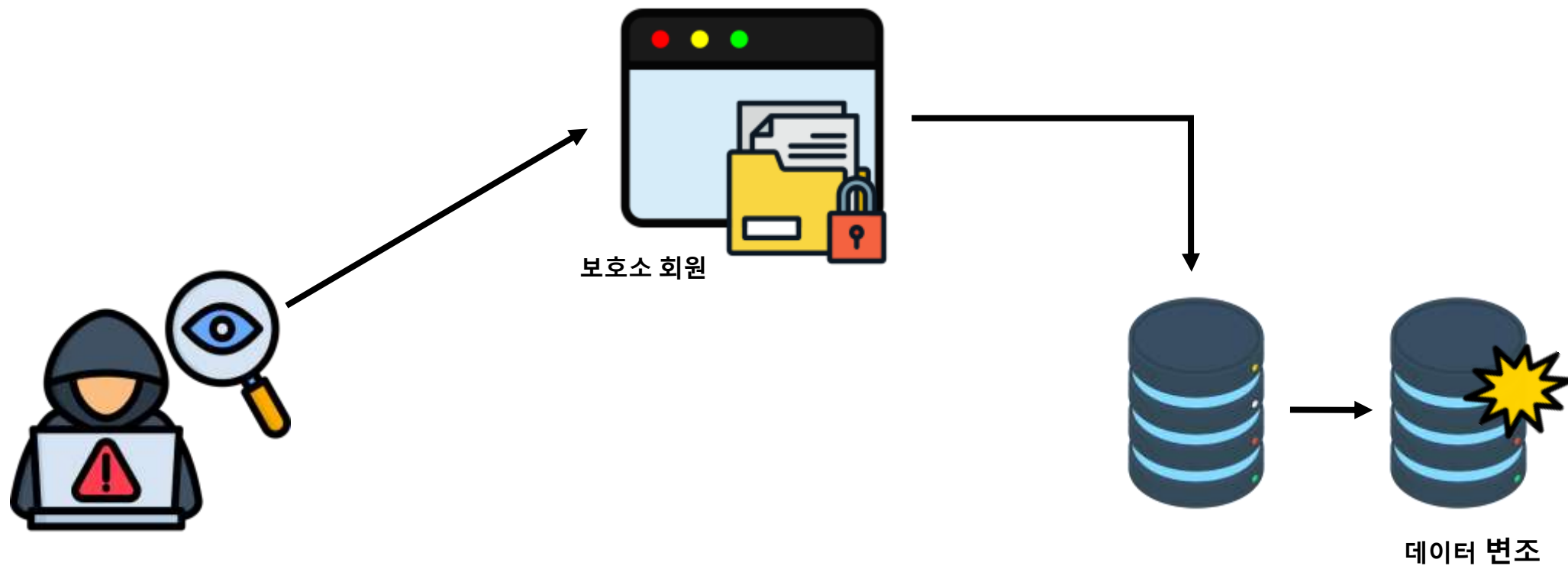


통합 관제 부재

SIEM 체계가 구축되어 있지 않아, 공격 발생 시점과  
전체적인 영향 범위를 신속하게 파악하는데 실패



## 시나리오



보안 사고

보호소 회원 전용 기능 권한 검증 미흡을 악용한 비인가 데이터 변조 공격





## 사업 목표

### 종합 보안 체계 구축

인프라(WEB, WAS, DB) 최적화, 보안장비 도입,  
SIEM 기반의 통합 보안관제 체계를 구축하여  
운영 환경 안정화

### 신속한 탐지 및 대응 체계 마련

로그 분석과 탐지 정책을 통해 공격 발생 시  
신속한 원인 파악 및 대응이 가능한 기반 확보



### 보안 위협 선제적 대응

취약점 진단 및 모의해킹을 통해 잠재적  
보안 위협을 사전에 식별하고 제거

### 지속 가능한 보안 운영 기준 수립

조치 가능 및 최종 결과보고서 작성을 통해 DDD가  
향후에도 스스로 보안 수준을 관리할 수 있는 운영 기준 마련



# 사용 도구

## 사용 도구



Packet Tracer  
6.2.0.0052



GNS3  
1.5.1



Putty  
0.83



NMAP  
7.94 SVN



Wireshark  
4.4.14



VMware  
17.6.2



Burp Suite  
2024.9.4



docker  
29.1.3

## 협업 도구



Google Drive



Notion



Slack



drow.io

## 사용 장비



Rocky Linux  
8.10



KALI  
2024.04



Ubuntu  
24.04.2



Php  
7.2.24



Windows Server  
2016



Windows  
11



MariaDB  
10.3.39



MySQL  
8.0.46



SOPHOS UTM 9  
9.720-5

SPIDER™

## 문서화 도구



PPT



Excel



Word



한글



**총 수행 기간 : 2026.06.04 ~ 2026.07.16 (총 31일)**

[illegible]



## 02 분석 및 점검

## 2026 주요정보통신기반시설 기술적 취약점 분석·평가방법 상세가이드

## 정보보호 컨설팅 기반 네트워크·웹 보안 강화 사업 제안서

### I. 사업 개요

1. 사업명 : 유기견 성향 분석 기반 추천 플랫폼 구축 및 정보보호 체계 강화 사업

### II. 추진 배경

최근 웹 서비스를 대상으로 한 개인정보 유출, 계정 탈취, 랜섬웨어 및 웹 취약점 공격이 고도화, 지속화되는 추세입니다. 서비스 운영 기업은 회원정보, 이용정보, 각종 신청 데이터 등 중요 자산을 보유하고 있어 보안 사고 발생 시 서비스 신뢰도 하락 및 심각한 개인정보 유출 피해로 이어질 수 있습니다. 이에 따라 전문 보안업체와 협력하여 전반적인 보안 체계를 강화하고자 합니다.

### III. 사업의 필요성

딩동독(DingDongDog!) 플랫폼은 회원 및 유기견 관련 핵심 데이터를 안전하게 보호하고 서비스 무결성을 확보하는 것을 사업의 최우선 목표로 합니다. 이를 위해 네트워크 망 분리, 다층 접근 통제, 실시간 보안 관제 체계를 구축하여 외부 위협을 원천 차단할 계획입니다. 또한 정기적인 취약점 진단과 개인정보 보호 고도화를 지속하여 이용자가 안심하고 사용할 수 있는 안정적인 디지털 환경을 실현하겠습니다.



## 본사 자산 목록 (33/22)

| 분류      | 장비       | 장비 대수 | 점검 대수 | 용도                               |
|---------|----------|-------|-------|----------------------------------|
| PC      | PC       | 12    | 1     | 각 부서 별 직원 PC                     |
| 리눅스 서버  | 웹 서버     | 1     | 1     | DDD 웹 서비스 제공                     |
|         | 로그 서버    | 1     | 1     | 로그 저장                            |
|         | DB서버     | 1     | 1     | 데이터베이스 저장 처리                     |
|         | DB 백업 서버 | 1     | 1     | DB 서버 백업 수행                      |
|         | 로그 백업 서버 | 1     | 1     | 로그 서버 백업 수행                      |
| 윈도우 서버  | DNS서버    | 1     | 1     | DNS 서버                           |
|         | DHCP서버   | 1     | 1     | 지사 직원 PC 대상 DHCP 주소 할당           |
| 네트워크 장비 | L2 스위치   | 5     | 5     | 각 부서 별 직원 PC 연결                  |
|         | L3 스위치   | 3     | 3     | VLAN 간 라우팅 및 내부망 트래픽 집선          |
|         | 라우터      | 3     | 3     | 내부망·DMZ·외부망 간 통신 경로 제공           |
| 보안 장비   | SIEM     | 1     | 1     | 로그 중앙 수집/분석하여 보안이벤트 탐지 관리        |
|         | UTM      | 1     | 1     | 네트워크 트래픽을 검사하여 공격을 차단            |
|         | WAF      | 1     | 1     | mod_security로 http 트래픽 모니터링 및 차단 |

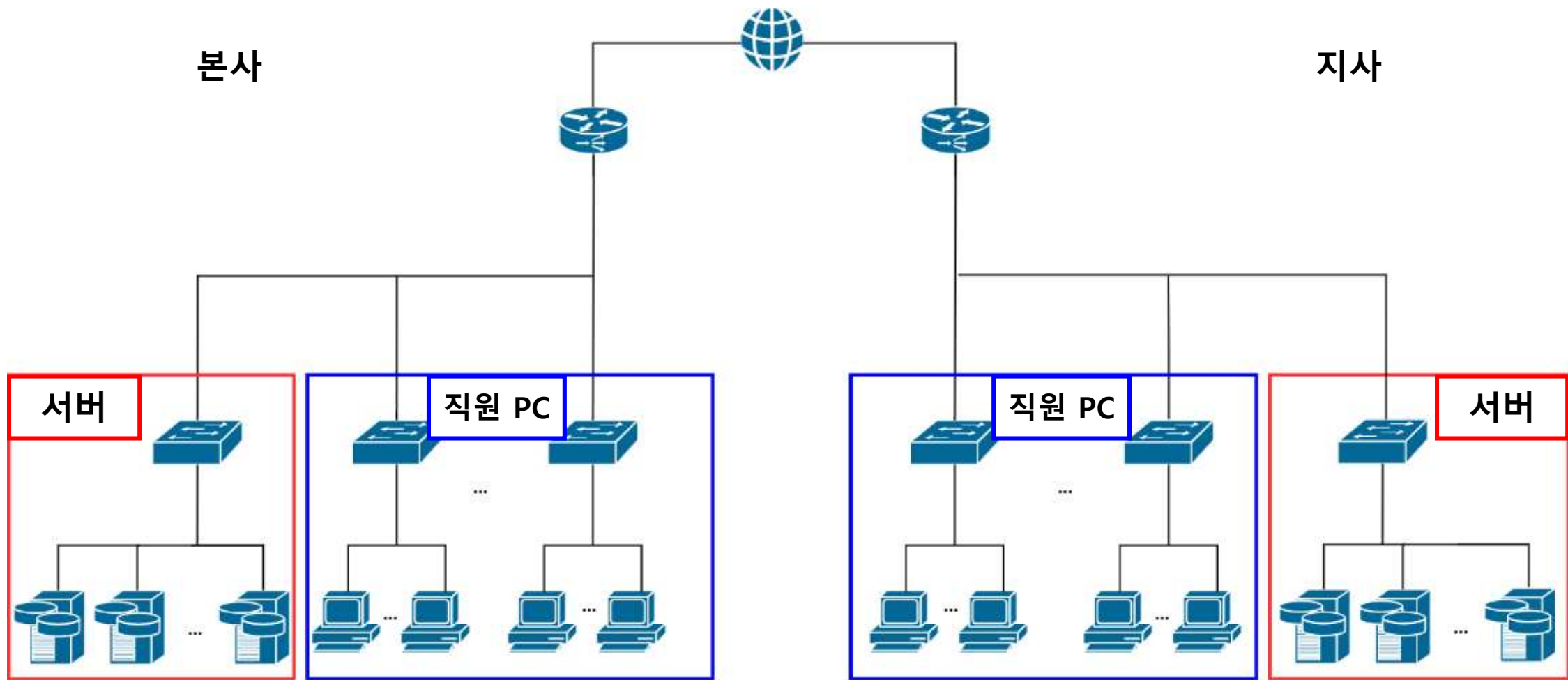


## 지사 자산 목록(30/21)

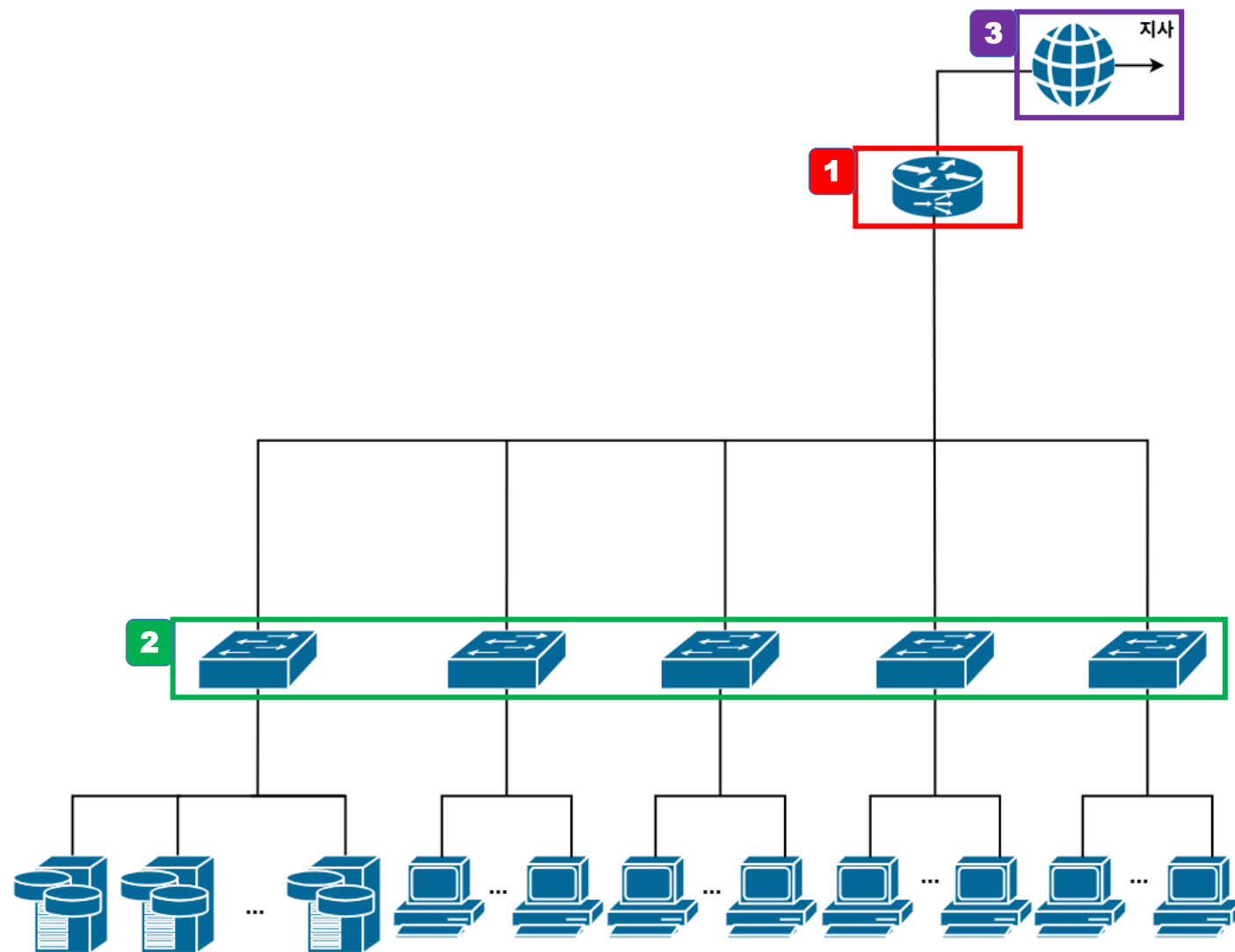
| 분류      | 장비       | 장비 대수 | 점검 대수 | 용도                      |
|---------|----------|-------|-------|-------------------------|
| PC      | PC       | 7     | 1     | 각 부서 별 직원 PC            |
| 리눅스 서버  | PHP 서버   | 1     | 1     | DDDM 웹 서비스 제공           |
|         | 로그 서버    | 1     | 1     | 로그 저장                   |
|         | DB서버     | 1     | 1     | 데이터베이스 저장 처리            |
|         | DB 백업 서버 | 1     | 1     | DB 서버 백업 수행             |
|         | 로그 백업 서버 | 1     | 1     | 로그 서버 백업 수행             |
| 윈도우 서버  | DNS서버    | 1     | 1     | DNS 서버                  |
|         | DHCP서버   | 1     | 1     | 본사 직원 PC 대상 DHCP 주소 할당  |
| 네트워크 장비 | L2 스위치   | 6     | 6     | 각 부서 별 직원 PC 연결         |
|         | L3 스위치   | 3     | 3     | VLAN 간 라우팅 및 내부망 트래픽 집선 |
|         | 라우터      | 3     | 3     | 내부망·DMZ·외부망 간 통신 경로 제공  |
| 보안 장비   | UTM      | 1     | 1     | 네트워크 트래픽을 검사하여 공격을 차단   |



## 기존 고객사 인프라





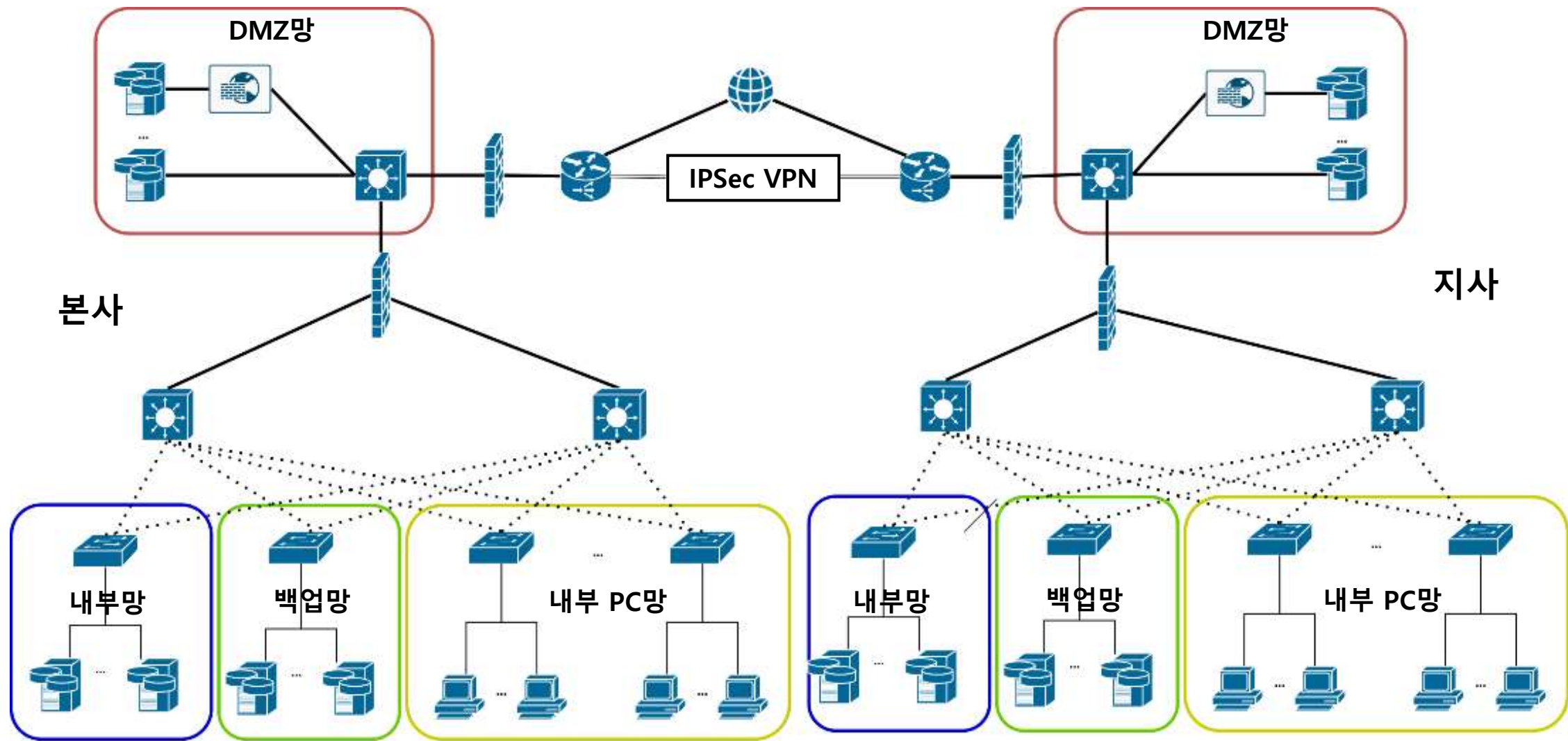


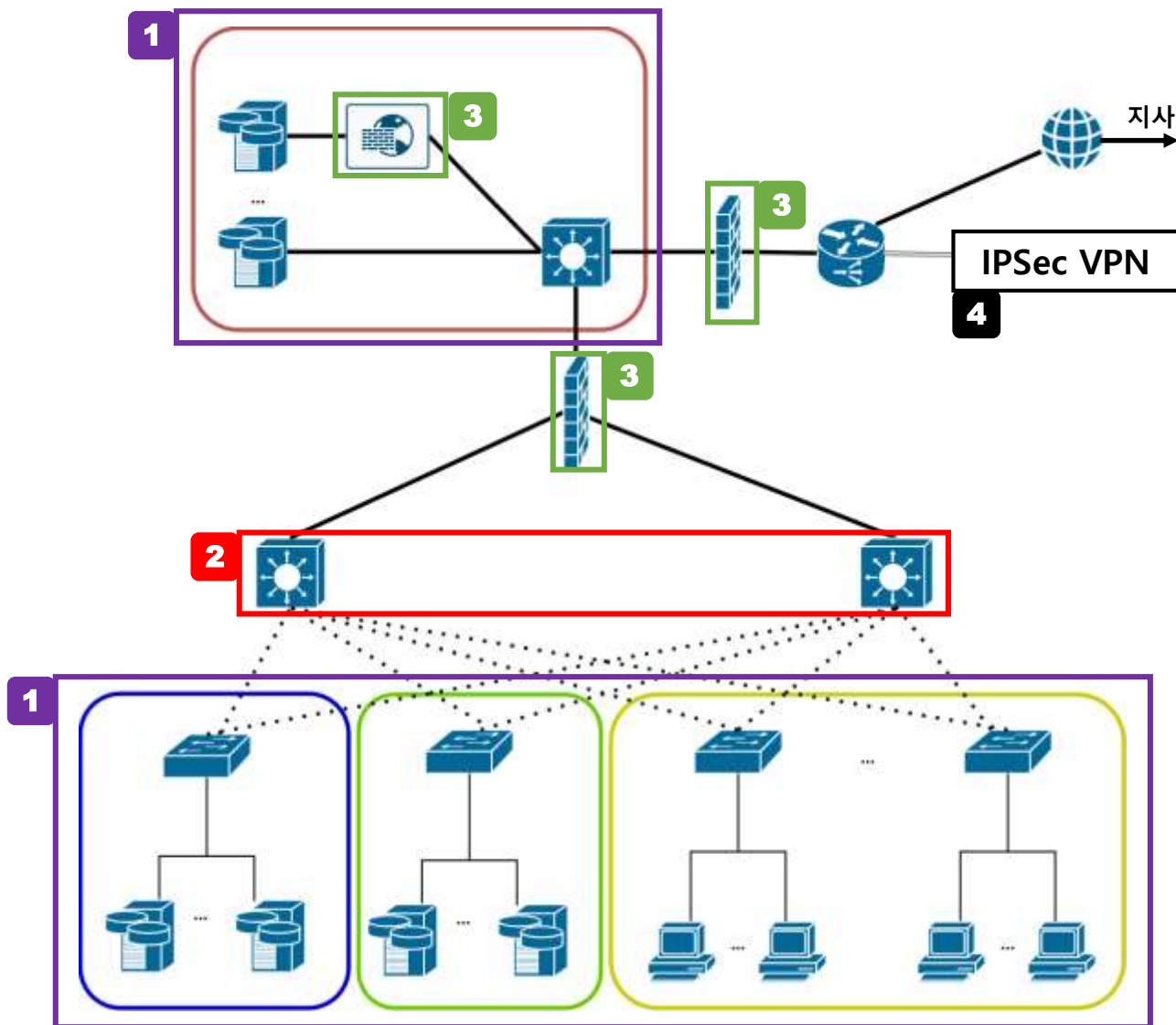
## 인프라 취약점

- 1** 보안장비 부재와 서버 보안 설정 미흡
- 2** 이중화 부재
- 3** 본사, 지사간 사설 통신망 부재



## 개선된 인프라





## 개선 사항

- 1** DMZ망 구축을 통한 내/외부망 분리
- 2** L3 Switch 이중화
- 3** 보안장비 도입
- 4** 본사/지사간 VPN 통신



**03**

**개인 발표**



서서울

- PM
- 배포
- 시나리오 기반 모의해킹 (본사/지사)



# 시나리오 기반 모의해킹(지사)

서서울

## SQL Injection 취약점 (1)

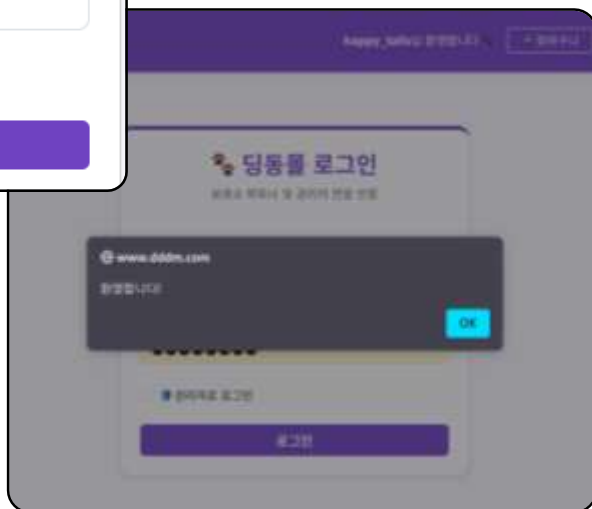
딩동물 로그인  
보호소 파트너 및 관리자 전용 인증

아이디  
' OR '1'='1' --

비밀번호

☐ 관리자로 로그인

로그인



- 진단 대상  
통합 로그인 인증 처리 모듈 (login\_proc.php)
- Prepared Statement를 적용하지 않고,  
외부 입력 값을 동적 문자열로 직접 조립하여  
실행하는 구조



# 시나리오 기반 모의해킹(지사)

서서울

## SQL Injection 취약점 (2)

1

```
16 user_id=' OR '1'='1' AND SUBSTRING(database(), 1, 1)='a'-- &user_pw=+
```



```
13 <script>
14   alert('정보가 일치하지 않습니다. ID/PW 또는 입력값을 확인하세요.');
```

2

```
16 user_id=' OR '1'='1' AND SUBSTRING(database(), 1, 1)='d'-- &user_pw=+
```



```
13 <script>
14   alert('환영합니다!');
```

- Boolean-Based Blind SQL Injection
- ' OR '1'='1' AND (SELECTSUBSTRING(database(), 1, 1)) = 'd' --  
맨 뒤에 적힌 단어를 바꿔가며 로그인  
성공할 때 까지 반복



# 시나리오 기반 모의해킹(지사)

서서울

## SQL Injection 취약점 (3)

```
16 user_id= OR '1'='1' ORDER BY 10-- &user_pw=+  
Response  
1 HTTP/1.1 200 OK  
2 Date: Tue, 30 Jun 2026 11:42:27 GMT  
3 Server: Apache/2.4.37 (Rocky Linux)  
4 X-Powered-By: PHP/7.2.24  
5 Expires: Thu, 19 Nov 1981 08:52:00 GMT  
6 Cache-Control: no-store, no-cache, must  
7 Pragma: no-cache  
8 Keep-Alive: timeout=5, max=100  
9 Connection: Keep-Alive  
10 Content-Type: text/html; charset=UTF-8  
11 Content-Length: 69  
12  
13 <script>  
14 alert('환영합니다!');  
15 location.href='main.php';  
16 </script>
```

```
16 user_id= OR '1'='1' ORDER BY 13-- &user_pw=+  
Response  
1 HTTP/1.1 200 OK  
2 Date: Tue, 30 Jun 2026 11:43:46 GMT  
3 Server: Apache/2.4.37 (Rocky Linux)  
4 X-Powered-By: PHP/7.2.24  
5 Expires: Thu, 19 Nov 1981 08:52:00 GMT  
6 Cache-Control: no-store, no-cache, must-revalidate  
7 Pragma: no-cache  
8 Keep-Alive: timeout=5, max=100  
9 Connection: Keep-Alive  
10 Content-Type: text/html; charset=UTF-8  
11 Content-Length: 72  
12  
13 일반회원 쿼리 실행 실패: Unknown column '13' in 'order clause'
```

- ORDER BY 1 -- 쿼리문 사용 한 컬럼 개수 파악
- 마지막 숫자를 하나씩 올리면서 요청을 보내고 쿼리 입력 실패가 뜨면 ddd\_user의 컬럼 개수 파악 가능
- 추후 UNION SELECT 공격까지 진행 가능





# 시나리오 기반 모의해킹(지사)

서서울

## SQL Injection 취약점 (4)

```
$user_id = $_POST['user_id'] ?? '';  
$user_pw = $_POST['user_pw'] ?? '';  
  
if ($login_type === 'admin') {  
    $query = "SELECT * FROM ddd_admin WHERE admin_id = '$user_id' AND admin_password = '$user_pw'";  
    $result = mysqli_query($conn, $query);  
  
    if ($row = mysqli_fetch_assoc($result)) {  
        $_SESSION['user_id'] = $row['admin_id'];  
        $_SESSION['user_type'] = 'a';  
    }  
}
```



```
$stmt = $conn->prepare("SELECT user_id, user_password, user_type  
FROM ddd_user WHERE user_id = ? AND user_password = ?");  
$stmt->bind_param("ss", $user_id, $user_pw);  
$stmt->execute();  
$result = $stmt->get_result();  
  
if ($row = $result->fetch_assoc()) {  
    $_SESSION['user_id'] = $row['user_id'];  
    $_SESSION['user_type'] = $row['user_type'];  
    echo "<script>alert('환영합니다!'); location.href='main.php';</script>";  
    exit;  
}
```

- prepare()를 사용해 쿼리를 서버에 보내  
구문분석을 하고 실행 단계에서 값만 매핑해서  
전달해 SQL Injection 방지
- bind\_param()을 통해 파라미터를 바인딩해  
입력한 값에 명령어가 포함되더라도 바인딩한  
파라미터로 인식해 SQL Injection 방어 가능



# 시나리오 기반 모의해킹(지사)

서서울

## IDOR 취약점(1)

```
MariaDB [ddm_db]> select * from ddm_cart;
```

| cart_id | user_id     | product_id | cart_quantity |
|---------|-------------|------------|---------------|
| 6       | with_dogs   | 19         | 1             |
| 7       | with_dogs   | 16         | 1             |
| 8       | happy_tails | 1          | 1             |
| 9       | blue_paw    | 9          | 1             |
| 10      | blue_paw    | 17         | 2             |

5 rows in set (0.006 sec)

- 진단 대상

`cart_update_proc.php`

`order_view.php`

`mypage_update.php`

- 서버에서 클라이언트가 요청한 정보에 대해 로그인 된 세션 사용자가 접근 권한을 갖는지 검증하는 **인가(Authorization)** 단계 누락



# 시나리오 기반 모의해킹(지사)

## 서서울

## IDOR 취약점(2)

- 평문으로 노출된 파라미터를 확인
- Burp Suite로 장바구니 수량 변경 패킷을 가로챈 뒤 cart\_id와 cart\_quantity를 조작하여 타인의 상품 정보를 변조

**Request**

Pretty Raw Hex

```
1 POST /ddm_php/cart_update_proc.php HTTP/1.1
2 Host: www.dddm.com
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/png,image/svg+xml,*/*;q=0.8
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Content-Type: application/x-www-form-urlencoded
8 Content-Length: 26
9 Origin: http://www.dddm.com
10 Connection: keep-alive
11 Referer: http://www.dddm.com/ddm_php/cart.php
12 Cookie: PHPSESSID=ekblt6broeti8a3ricavp8da28
13 Upgrade-Insecure-Requests: 1
14 Priority: u=0, i
15
16 cart_id=10&cart_quantity=2
```

**Request**

Pretty Raw Hex

```
1 POST /ddm_php/cart_update_proc.php HTTP/1.1
2 Host: www.dddm.com
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/png,image/svg+xml,*/*;q=0.8
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Content-Type: application/x-www-form-urlencoded
8 Content-Length: 27
9 Origin: http://www.dddm.com
10 Connection: keep-alive
11 Referer: http://www.dddm.com/ddm_php/cart.php
12 Cookie: PHPSESSID=ekblt6broeti8a3ricavp8da28
13 Upgrade-Insecure-Requests: 1
14 Priority: u=0, i
15
16 cart_id=8&cart_quantity=100
```

**Response**

Pretty Raw Hex Render

```
1 HTTP/1.1 302 Found
2 Date: Sat, 27 Jun 2026 01:45:01 GMT
3 Server: Apache/2.4.37 (Rocky Linux)
4 X-Powered-By: PHP/7.2.24
5 Expires: Thu, 19 Nov 1981 08:52:00 GMT
6 Cache-Control: no-store, no-cache, must-revalidate
7 Pragma: no-cache
8 Location: cart.php
9 Content-Length: 0
10 Keep-Alive: timeout=5, max=100
11 Connection: Keep-Alive
12 Content-Type: text/html; charset=UTF-8
13
14
```



# 시나리오 기반 모의해킹(지사)

서서울

## IDOR 취약점(3)

내 장바구니

| 선택                                  | 상품 정보                                                                                   | 가격      | 수량                               | 합계         | 삭제 |
|-------------------------------------|-----------------------------------------------------------------------------------------|---------|----------------------------------|------------|----|
| <input checked="" type="checkbox"/> |  수제 간식 | 42,000원 | <input type="text" value="100"/> | 4,200,000원 | ×  |

결제 금액

총 상품 금액 4,200,000원

최종 결제 금액 4,200,000원

구매하기

```
MariaDB [ddm_db]> select * from ddm_cart;
```

| cart_id | user_id     | product_id | cart_quantity |
|---------|-------------|------------|---------------|
| 6       | with_dogs   | 19         | 1             |
| 7       | with_dogs   | 16         | 1             |
| 8       | happy_tails | 1          | 100           |
| 9       | blue_paw    | 9          | 1             |
| 10      | blue_paw    | 17         | 2             |



# 시나리오 기반 모의해킹(지사)

## 서서울

## IDOR 취약점(4)

```
$cart_id = isset($_POST['cart_id']) ? (int)$_POST['cart_id'] : 0;  
$cart_quantity = isset($_POST['cart_quantity']) ? (int)$_POST['cart_quantity'] : 0;  
  
if ($cart_id > 0 && $cart_quantity > 0) {  
    $query = "UPDATE ddm_cart  
              SET cart_quantity = $cart_quantity  
              WHERE cart_id = $cart_id";  
  
    $result = mysqli_query($conn, $query);  
}
```



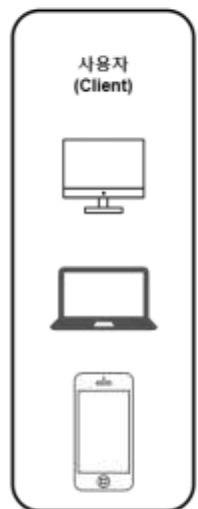
```
$cart_id = (int)$_POST['cart_id'];  
$cart_quantity = (int)$_POST['cart_quantity'];  
  
$session_user_id = $_SESSION['user_id'];  
  
$stmt = $conn->prepare("UPDATE ddm_cart SET cart_quantity = ? WHERE cart_id = ? AND user_id = ?");  
$stmt->bind_param("iis", $cart_quantity, $cart_id, $session_user_id);  
$stmt->execute();
```

- 강제 정수 형 변환(Type Casting)을 통한 SQL Injection 및 인자 변조 1차 차단
- 서버 측 웹 세션에서 안전하게 로그인 된 사용자의 ID 참조
- Prepared Statement 적용 및 세션 ID 결합 검증 타인의 cart\_id를 변조하여 전송하더라도 세션 소유주와 매칭되지 않아 공격 차단



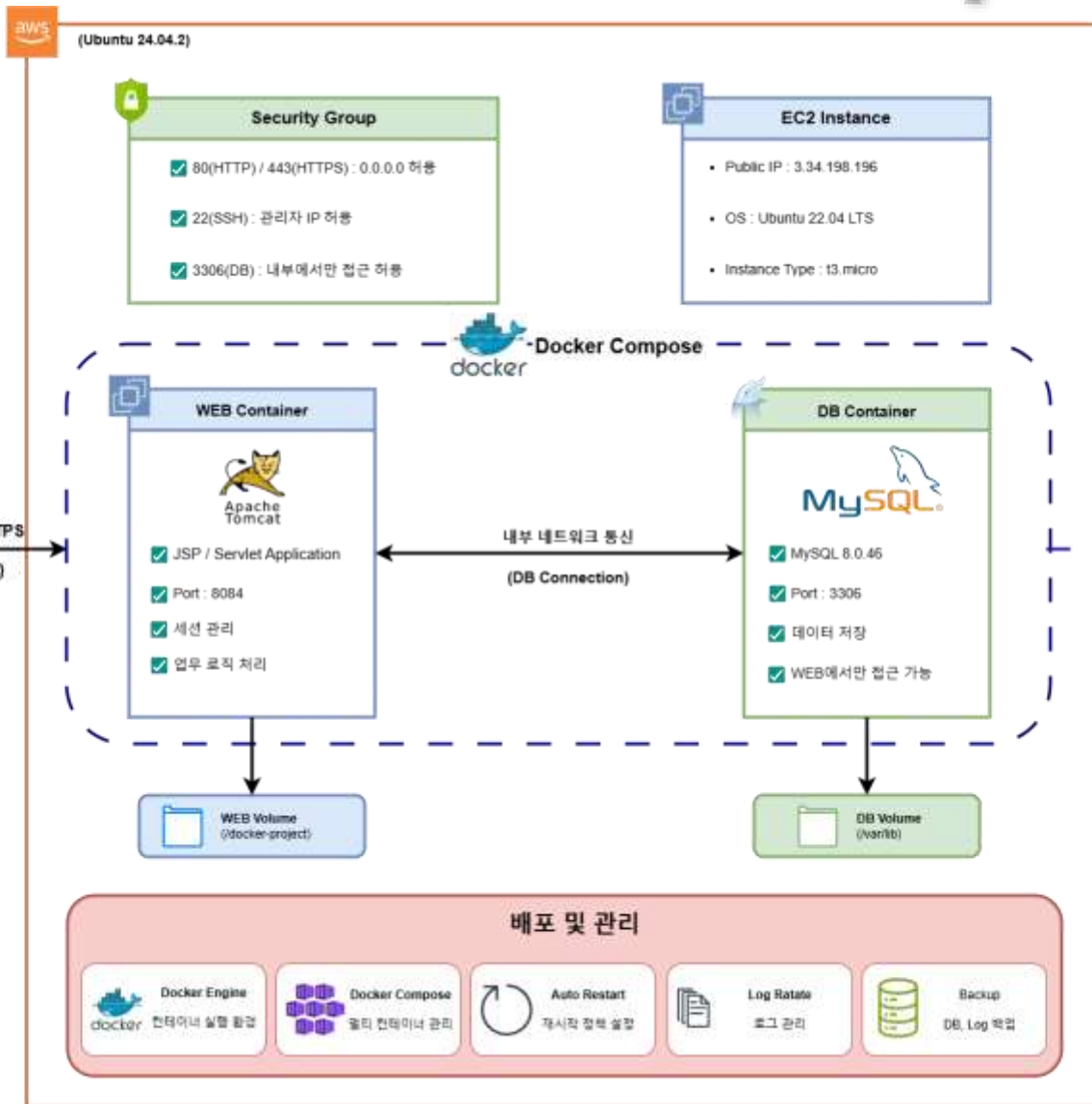
# 배포 아키텍처

서서울



## 구성 요약

- ✓ EC2 1대에 Docker Compose 기반 배포
- ✓ WEB(Tomcat) + DB(MySQLDB) 컨테이너 구성
- ✓ DB는 내부 네트워크에서만 접근 가능
- ✓ 불용을 이용한 데이터/로그 연속성 확보
- ✓ Security Group으로 외부 접근 제어
- ✓ S3, CloudWatch 연동으로 백업/모니터링





# Docker Compose 배포

- docker-compose.yml 사용해 두 컨테이너 한 번에 실행
- docker compose -d --build 명령어를 사용해 하나의 네트워크로 연결하여 통신

[illegible]



## Secure coding 중요성

```
$stmt = $conn->prepare("SELECT user_id, user_password, user_type  
FROM ddd_user WHERE user_id = ? AND user_password = ?");  
$stmt->bind_param("ss", $user_id, $user_pw);
```

```
$cart_id = (int)$_POST['cart_id'];  
$cart_quantity = (int)$_POST['cart_quantity'];  
$session_user_id = $_SESSION['user_id'];  
$stmt = $conn->prepare("UPDATE ddm_cart SET cart_quantity = ? WHERE cart_id = ? AND user_id = ?");  
$stmt->bind_param("iis", $cart_quantity, $cart_id, $session_user_id);  
$stmt->execute();
```

```
if ($row && ($user_pw === $row['user_pw'])) {  
    session_regenerate_id(true);  
    $_SESSION['user_id'] = $row['user_id'];  
    $_SESSION['user_type'] = $row['user_type'];  
}
```

- 한 줄도 안되는 짧은 코드로 SQL Injection, IDOR, Session Fixation 등의 치명적인 취약점 방어가능

| 취약점              | Secure Coding               | 효과              |
|------------------|-----------------------------|-----------------|
| SQL Injection    | Prepared Statement          | SQL 조작 차단       |
| IDOR             | 사용자 권한 검증                   | 타 사용자 데이터 접근 차단 |
| Session Fixation | session_regenerate_id(true) | 세션 탈취 방지        |





감사합니다.

서서울 | 윤철민 | 오명근 | 서정원 | 이주환